



DDoS只有爆流量? 從OSI七層拆解AWS DDoS防護思維

林家瑋 (Ray Lin)
2026/07





• 全球首批 GCR首位 AWS Security Hero

• iFUS System Consultants Ltd. - CISO / CAIO

• DataBrushing.ai - CDO

• 寓意科技(fable) - 資安顧問總監

• 長宏專案(PM-ABC) - PMI授權培訓講師

• 全智網科技(AIN) - AWS Champion授權講師 / ISC2授權講師

• PMI Taiwan獎項辦公室(PTGA) - 執行長

• ISC2 Taipei Chapter - 理事 / 媒體公關委員會 主委

• AWS User Group DevSecOps Taiwan - 共同創辦人

• 登豐數位、鑑智實相、捷虹資訊、德慎精算、睿峯管顧 - 顧問 / 講師

• 曾服務於美商、日商、新創、上市櫃、跨國集團；曾任CEO、COO、產品暨IT主管、業務主管、資深SI工程師與資深PG

• 曾獲台灣發明家創意獎、ISC2國際資安新星專家獎、PMI-TW優良志工獎 / 績優執行理監事、翻譯出版7本知名敏捷書籍



| 巨匠電腦 - SSDLC資安講師

| 台灣數位安全聯盟(TWCSA) - 理事

| DevSecOps Taiwan - 社長

阻斷服務不是只有DDoS

- **阻斷服務攻擊(DoS, Denial-of-service Attack)**: 阻止對資源的授權存取或延遲關鍵操作的時間
 - **碎片攻擊(Fragmentation Attack)**: 攻擊者刻意發送異常或重疊的IP碎片封包, 讓接收端無法正常重組封包。可能造成系統資源耗盡、封包處理失敗, 甚至使舊版作業系統當機, 例如淚珠攻擊(Teardrop), 手法如下(Fragment 2與Fragment 3發生重疊)
 - Fragment 1, Offset = 0
 - Fragment 2, Offset = 100
 - Fragment 3, Offset = 80
 - **死亡之Ping(POD, Ping of Death)**: Windows的ping指令預設Payload為32 Bytes(不同作業系統可能不同), 但IPv4封包最大長度為64KB。Ping of Death是利用IP碎片, 使重組後封包超過此限制, 而非單純送出較大的Ping
 - **分散式阻斷服務攻擊(DDoS Attack, Distributed Denial-of-Service)**

分散式阻斷服務攻擊(DDoS)

- 分散式阻斷服務攻擊(DDoS Attack, Distributed Denial-of-Service)
透過大量流量、連線、請求或協定濫用，讓目標服務資源耗盡，導致系統變慢、逾時或無法提供服務

OSI Model Layers		
L7	Application Layer	HTTP Flood, Cache-busting DNS Query Flood
L6	Presentation Layer	SSL/TLS Abuse TLS Handshake Flood
L5	Session Layer	不適用
L4	Transport Layer	Connection Flood SYN Flood UDP Reflection ICMP Flood Smurf
L3	Network Layer	
L2	Data Link Layer	不適用
L1	Physical Layer	不適用

Copyright 林家瑋(Ray Lin) / iFUS System Consultants Ltd. 5

分散式阻斷服務攻擊(DDoS)



DataBrushing.AI



艾美詩系統顧問有限公司

指標 資訊

2026-03-20T14:00:00



2026-03-20T17:00:00



UTC 時區



動作



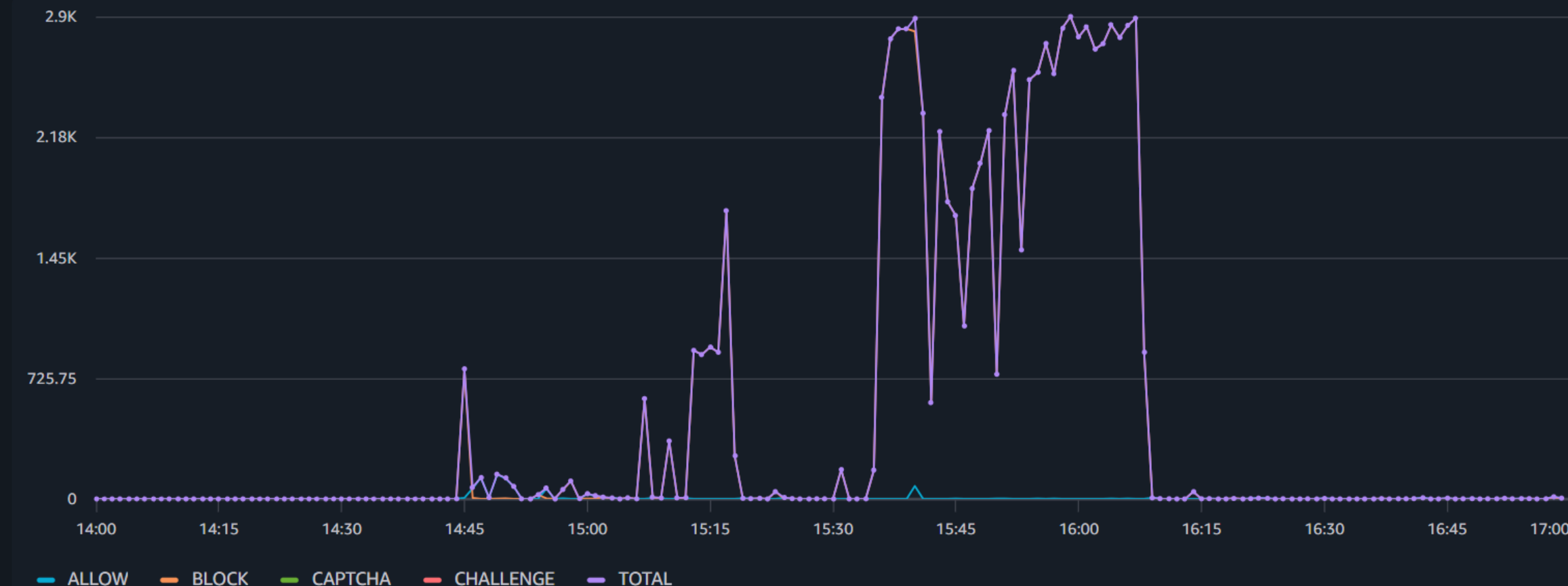
調查



行



動作總計



分散式阻斷服務攻擊(DDoS)

日誌群組-熱門客戶IP: aws-waf-logs-ifus

#	ClientIP	RequestCount
1	94.156.205.117	76310
2	185.213.82.27	5552
3	185.213.82.230	1350
4	185.213.82.171	1180
5	185.213.82.165	727
6	150.116.68.82	644
7	52.23.63.230	79
8	125.227.73.153	62
9	219.91.17.151	45

日誌群組-熱門國家/地區: aws-waf-logs-ifus

#	Country	RequestCount
1	TW	85879
2	US	227
3	FR	91
4	JP	22
5	GB	19
6	SG	12
7	CN	11
8	IN	11
9	DE	9

CPU Utilization: Average

Percent

41.1%

21.2%

1.26%

14:00 14:30 15:00 15:30 16:00 16:30 17:00

i-03806173b80f41946 (iFUS System Consultants Ltd.)

i-04ced38b21caa7cb8 (AgileToolPlatform)

NetworkIn: Average

Bytes

5.209M

2.609M

8.551k

14:00 14:30 15:00 15:30 16:00 16:30 17:00

i-03806173b80f41946 (iFUS System Consultants Ltd.)

i-04ced38b21caa7cb8 (AgileToolPlatform)

NetworkOut: Average

Bytes

5.61M

2.905M

199.6k

14:00 14:30 15:00 15:30 16:00 16:30 17:00

i-03806173b80f41946 (iFUS System Consultants Ltd.)

i-04ced38b21caa7cb8 (AgileToolPlatform)

L3 Network & L4 Transport - DDoS

• ICMP Flood, Smurf

- 駭客偽裝成受害主機IP，發送大量ICMP請求，使Server與受害主機不堪重負
- 如果是發送到廣播IP，網路上的所有設備都會對這些請求作出回應，發送大量回應訊息來淹沒受害主機

• UDP Reflection Attack

是一種反射放大型DDoS，攻擊者偽造受害者IP，向第三方伺服器發送UDP請求，讓第三方伺服器把回應流量送到受害者
 DNS請求60Byte可被放大為3000Byte以上
 NTP Monlist甚至可以放大206倍

OSI Model Layers

L7	Application Layer	HTTP Flood, Cache-busting DNS Query Flood
L6	Presentation Layer	SSL/TLS Abuse TLS Handshake Flood
L5	Session Layer	不適用
L4	Transport Layer	Connection Flood SYN Flood UDP Reflection ICMP Flood Smurf
L3	Network Layer	
L2	Data Link Layer	不適用
L1	Physical Layer	不適用

L3 Network & L4 Transport - DDoS

- **Connection Flood**

攻擊者建立大量TCP連線並長時間佔用，耗盡伺服器的連線資源

Nginx預設Worker Connections約1024

worker_connections = 1024

worker_processes = 4

理論上最多 $1024 \times 4 \approx 4096$ Connections

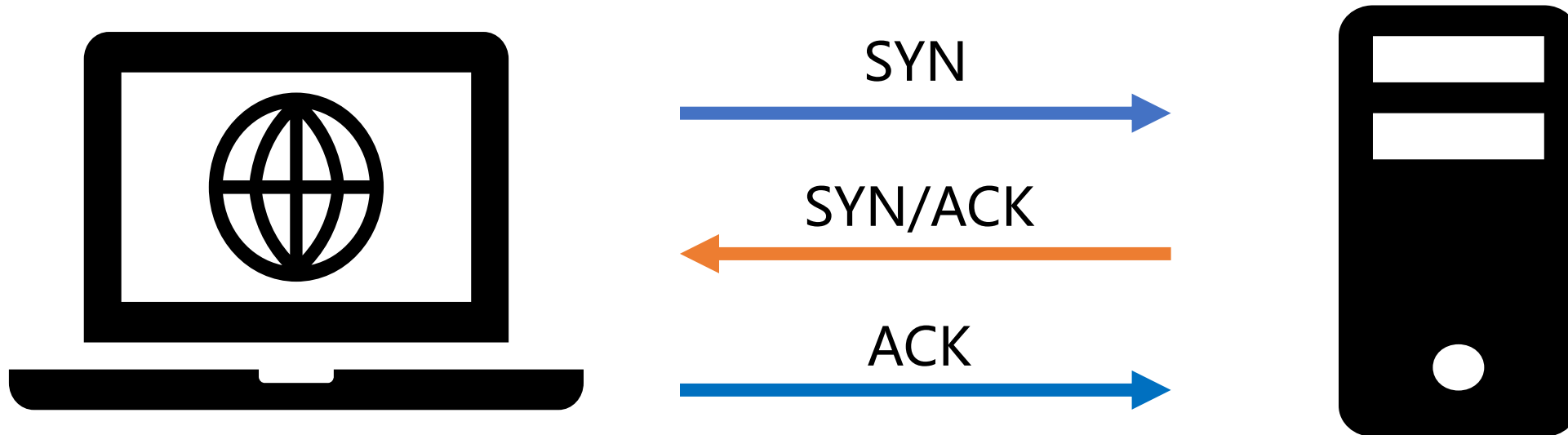
- **SYN Flood**

SYN Flood是經典的TCP層DDoS攻擊，攻擊者大量送出SYN封包要求建立連線，但不完成三向交握，導致伺服器維持大量半開連線

OSI Model Layers

L7	Application Layer	HTTP Flood, Cache-busting DNS Query Flood
L6	Presentation Layer	SSL/TLS Abuse TLS Handshake Flood
L5	Session Layer	不適用
L4	Transport Layer	Connection Flood SYN Flood UDP Reflection ICMP Flood Smurf
L3	Network Layer	
L2	Data Link Layer	不適用
L1	Physical Layer	不適用

TCP三次交握



L6 Presentation - DDoS

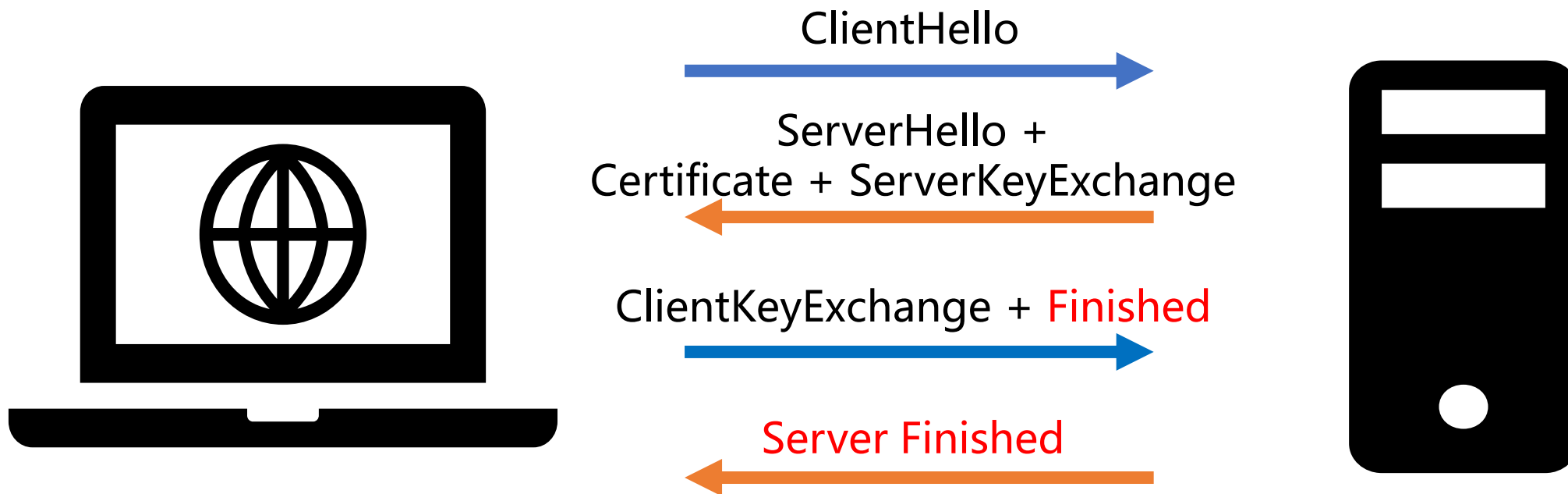
- **SSL/TLS Abuse,
TLS Handshake Flood**

針對TLS/SSL加密機制的濫用攻擊，攻擊者大量建立HTTPS連線、觸發TLS Handshake、重新協商或消耗加解密運算資源

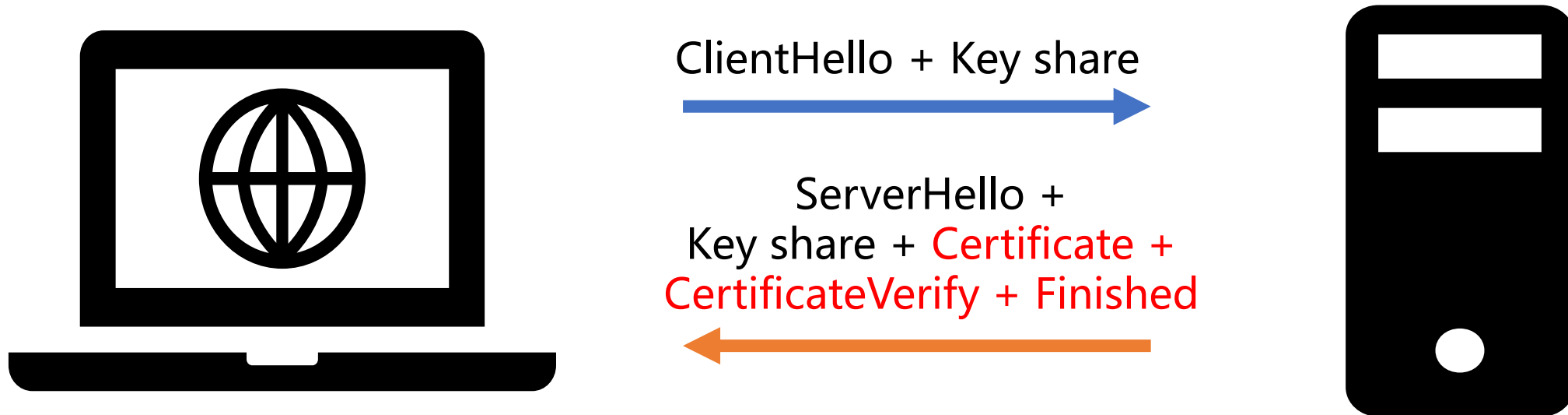
流量量不一定非常大，但每一個TLS連線都可能消耗較多運算資源，所以攻擊效率較高

OSI Model Layers		
L7	Application Layer	HTTP Flood, Cache-busting DNS Query Flood
L6	Presentation Layer	SSL/TLS Abuse TLS Handshake Flood
L5	Session Layer	不適用
L4	Transport Layer	Connection Flood SYN Flood UDP Reflection ICMP Flood Smurf
L3	Network Layer	
L2	Data Link Layer	不適用
L1	Physical Layer	不適用

TLS 1.2 (2-RTT, 2 round-trip time)



TLS 1.3 (1-RTT, 1 round-trip time)



L7 Application - DDoS

- **HTTP Flood**

攻擊者發出大量HTTP GET或POST請求，讓Web, API, DB等Server忙於處理請求

- **Cache-busting**

調整URL參數的查詢字元，瀏覽器會認為URL不同而繞過快取，例如 ?v=1.1 → ?v=1.2

- **DNS Query Flood**

大量向DNS伺服器發送查詢請求，使DNS伺服器負載升高，常見手法如

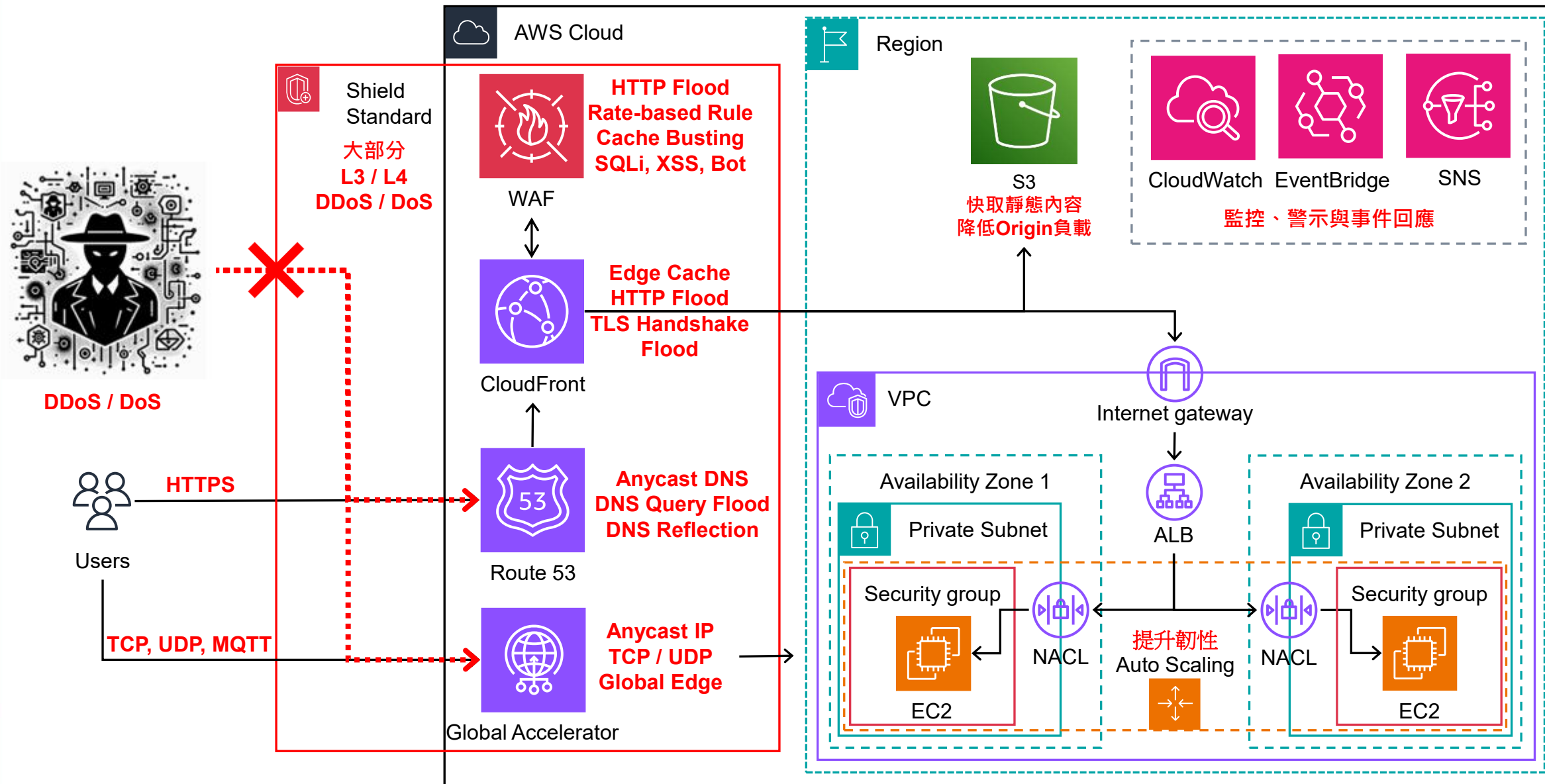
- 固定網域大量查詢
- 大量查詢不存在或隨機產生的子網域

OSI Model Layers		
L7	Application Layer	HTTP Flood, Cache-busting DNS Query Flood
L6	Presentation Layer	SSL/TLS Abuse TLS Handshake Flood
L5	Session Layer	不適用
L4	Transport Layer	Connection Flood SYN Flood UDP Reflection ICMP Flood Smurf
L3	Network Layer	
L2	Data Link Layer	不適用
L1	Physical Layer	不適用

300萬支智能牙刷進行DDoS攻擊

- [Fortinet報告](#)指出，智能牙刷使用易受感染的Java作業系統，駭客僅**幾分鐘**即可控制它們，約有**300萬支智能牙刷**感染木馬被利用於DDoS攻擊
- [GCP儲存空間被DDoS攻擊 收到鉅額帳單](#)
 - Google Cloud Storage的圖片被DDoS攻擊，持續下載同一張圖片兩天(500MiB/s, 每秒8k requests來自歐美的七個IP位址)，被收**USD 11,000**鉅額帳單
- [雲端主機淪為DDoS跳板 收到鉅額帳單](#)
 - 雲端主機被駭客利用成為DDoS攻擊跳板機，對其他企業網站發起大規模流量攻擊，未有監控機制，最後收到鉅額帳單





DevSecOps Taiwan



林家瑋|大Ray@DevSecOps社長

DevSecOps Taiwan (2500+)



https://bit.ly/AG3_DevSecOps



- 每個月免費線上分享
 - 每月固定一場 👉 1~2小時分享
 - 不定期快閃 👉 0.5~1小時分享
- 社群分享主題與交流方向
 1. Agile / Waterfall / Hybrid
 2. DevSecOps (DevOps + Security)
 3. Secure Coding
 4. AI Security
 5. Cybersecurity
 6. Cloud Security (AWS / Azure / GCP)



歡迎加我好友



Email: ray.lin@ifus.tw